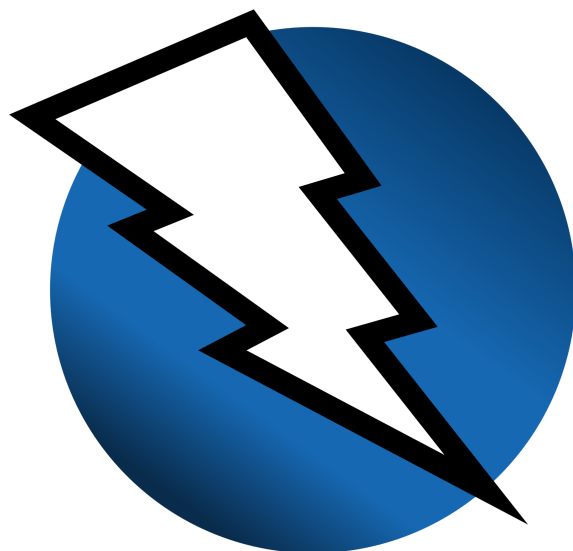


---

# **OWASP ZAP : WEB SECURITY SCANNER**

---



## **Introduction**

OWASP ZAP (Zed Attack Proxy) is a free, open-source security tool designed to help ethical hackers, developers, and security analysts find vulnerabilities in web applications. ZAP acts as a man-in-the-middle proxy, intercepting and analyzes traffic between your browser and a web server.

## **Key Features :**

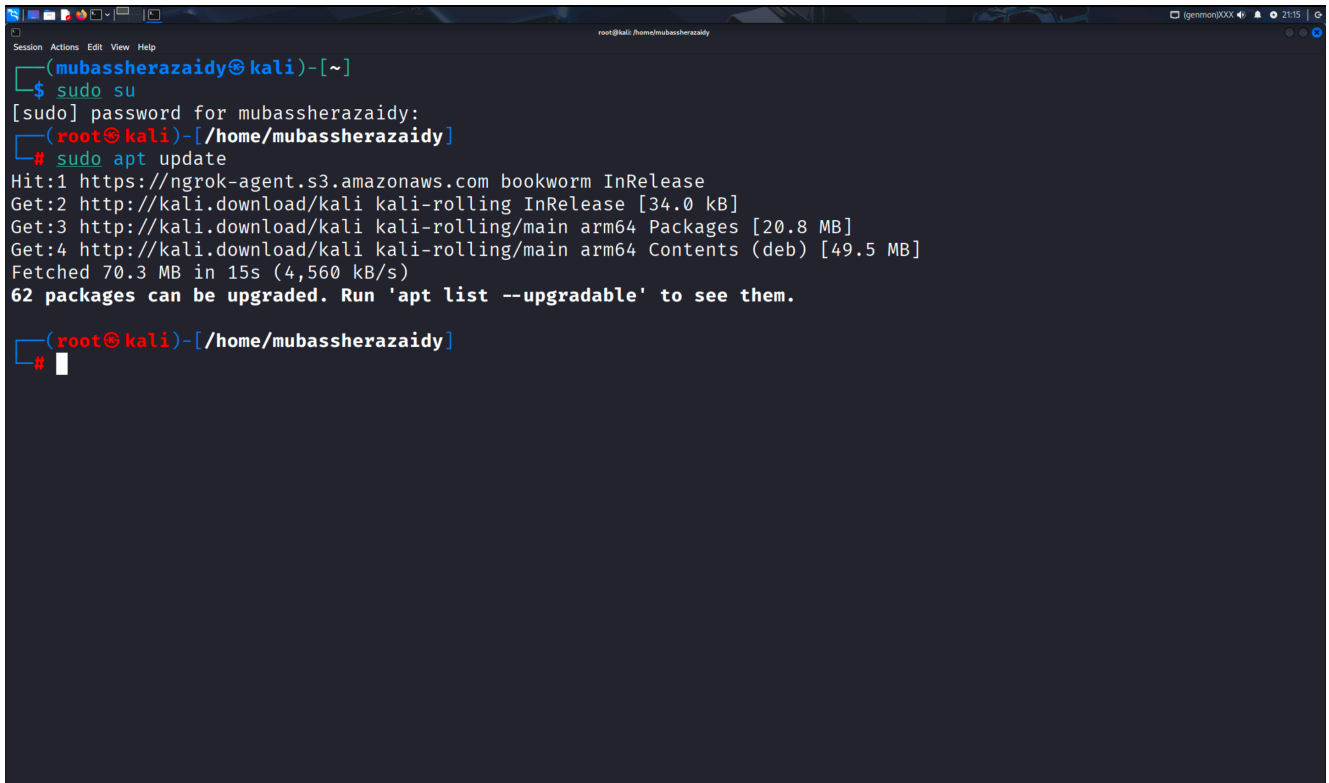
- Automated Scanner: Quickly scans for common vulnerabilities.
- Spidering: Crawls websites to map out all accessible content.
- Passive & Active Scanning: Detects issues quietly or probes for deeper flaws.
- Intercepting Proxy: Captures and modifies HTTP/S traffic.
- Fuzzer: Sends crafted payloads to test input fields.
- Session Handling: Supports login workflows and authenticated scans.
- Beginner-Friendly Interface: Visual layout with tabs for history, alerts, and traffic inspection.

## **Objective:**

To identify and analyze web application vulnerabilities using both automated and manual testing techniques in a controlled lab environment.

# ZAP Setup and Automated Scan

STEP 1 : Update your system - Run `sudo apt update` to check for new package updates.

A terminal window screenshot showing a user named mubassherazaidy on a Kali Linux machine. The user runs 'sudo su' to become root, then 'sudo apt update'. The terminal output shows the system checking for updates from various sources, including ngrok-agent.s3.amazonaws.com and kali-rolling. It reports that 62 packages can be upgraded. The user then runs 'apt list --upgradable' but the output is not visible in the screenshot.

```
mubassherazaidy@kali:~$ sudo su
[sudo] password for mubassherazaidy:
root@kali:~/home/mubassherazaidy# sudo apt update
Hit:1 https://ngrok-agent.s3.amazonaws.com bookworm InRelease
Get:2 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:3 http://kali.download/kali kali-rolling/main arm64 Packages [20.8 MB]
Get:4 http://kali.download/kali kali-rolling/main arm64 Contents (deb) [49.5 MB]
Fetched 70.3 MB in 15s (4,560 kB/s)
62 packages can be upgraded. Run 'apt list --upgradable' to see them.

root@kali:~/home/mubassherazaidy#
```

STEP 2 : Install ZAP - Run `sudo apt install zaproxy` to install the tool.

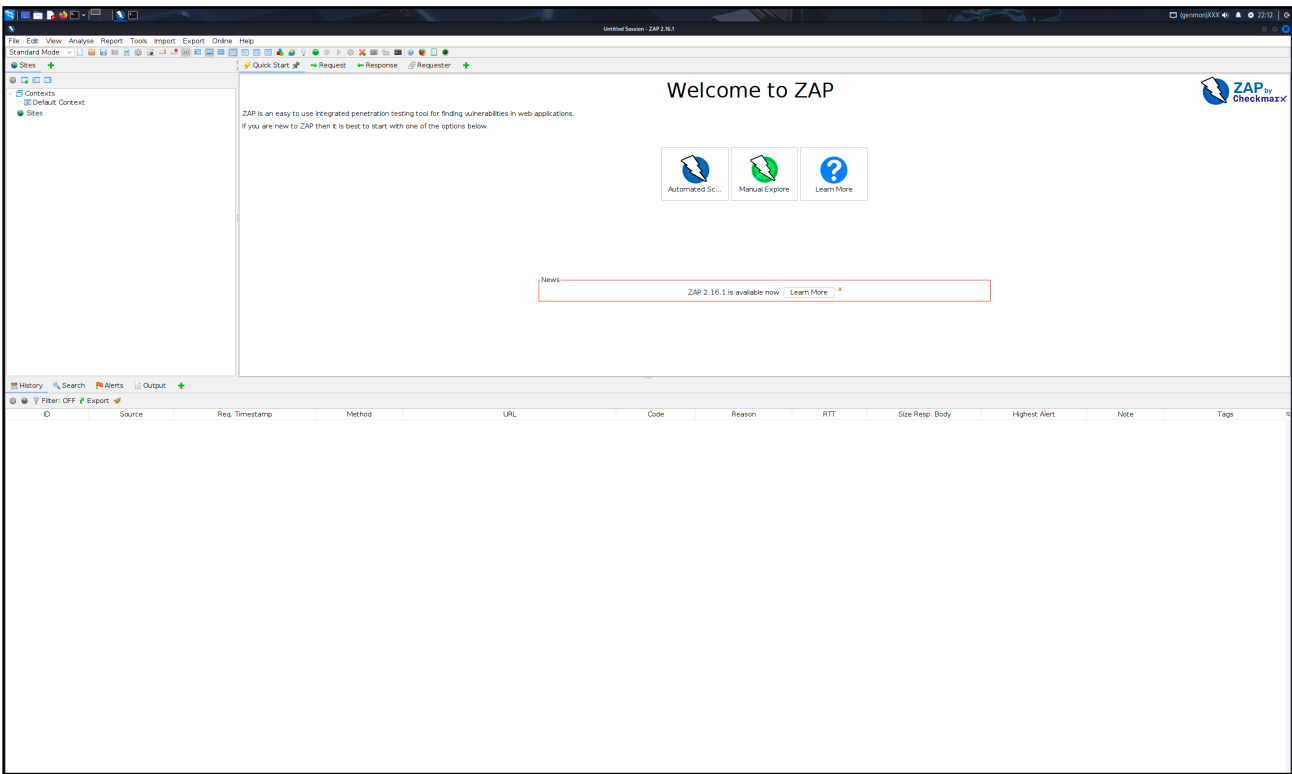
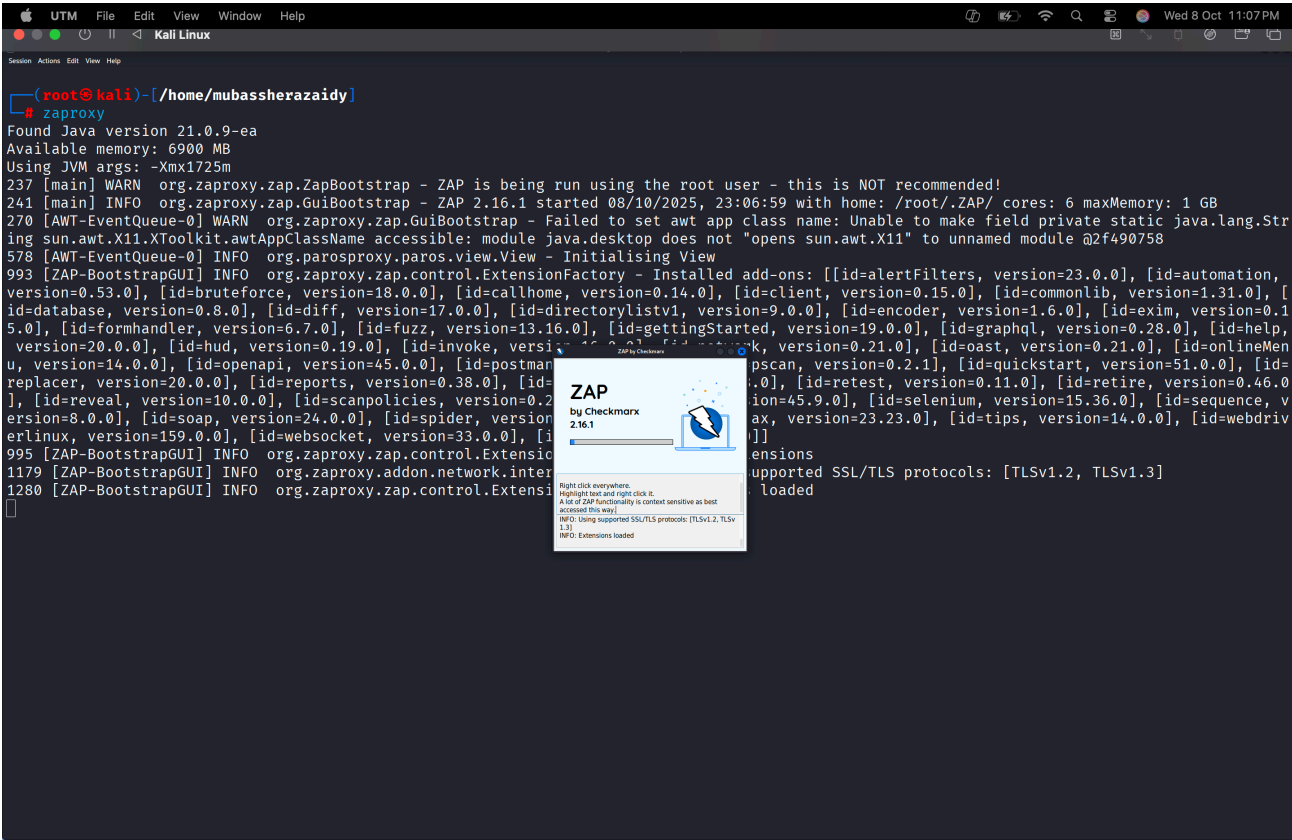
```
(root@kali)-[/home/mubassherazaidy]
# sudo apt install zaproxy
Installing:
  zaproxy

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 62
  Download size: 214 MB
  Space needed: 271 MB / 36.1 GB available

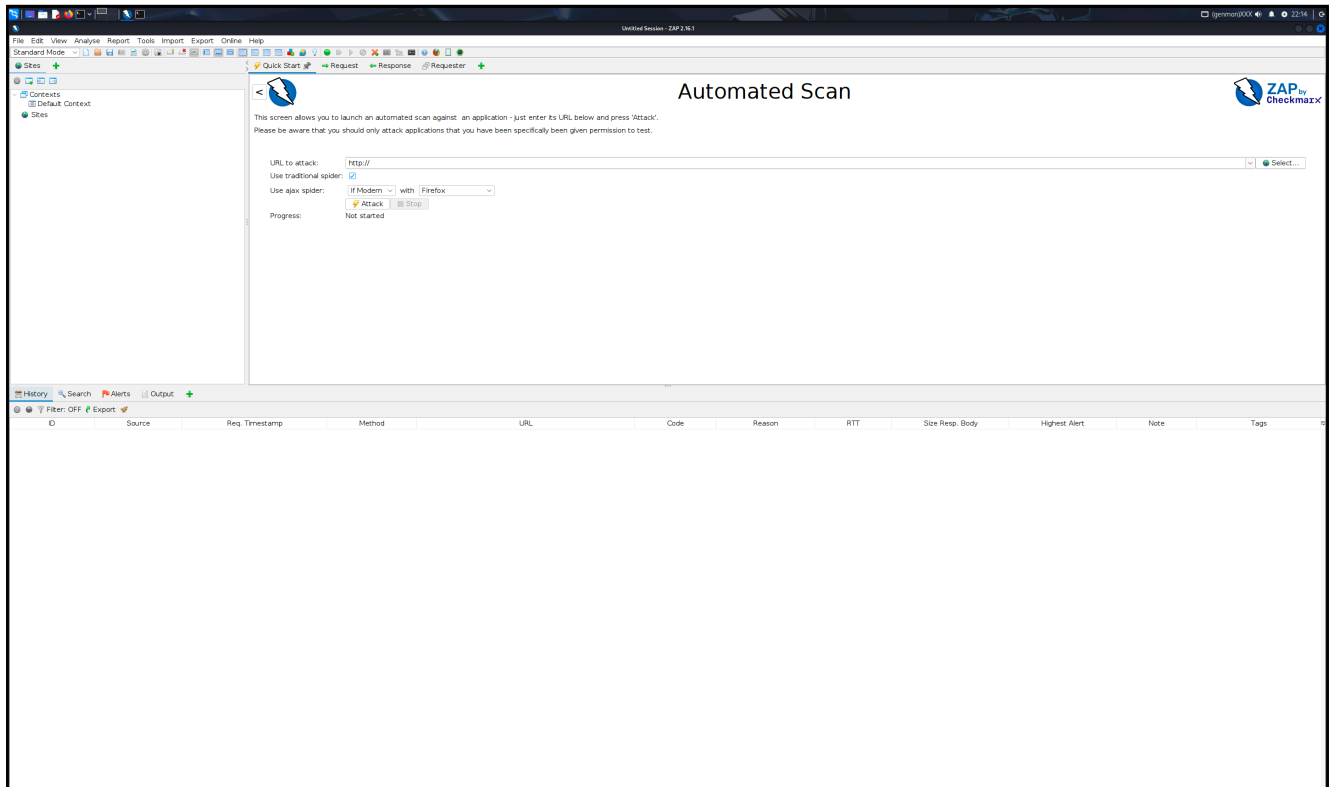
Get:1 http://kali.download/kali kali-rolling/main arm64 zaproxy all 2.16.1-0kali1 [214 MB]
Fetched 214 MB in 37s (5,862 kB/s)
Selecting previously unselected package zaproxy.
(Reading database ... 417479 files and directories currently installed.)
Preparing to unpack .../zaproxy_2.16.1-0kali1_all.deb ...
Unpacking zaproxy (2.16.1-0kali1) ...
Setting up zaproxy (2.16.1-0kali1) ...
Processing triggers for kali-menu (2025.4.1) ...

(root@kali)-[/home/mubassherazaidy]
#
```

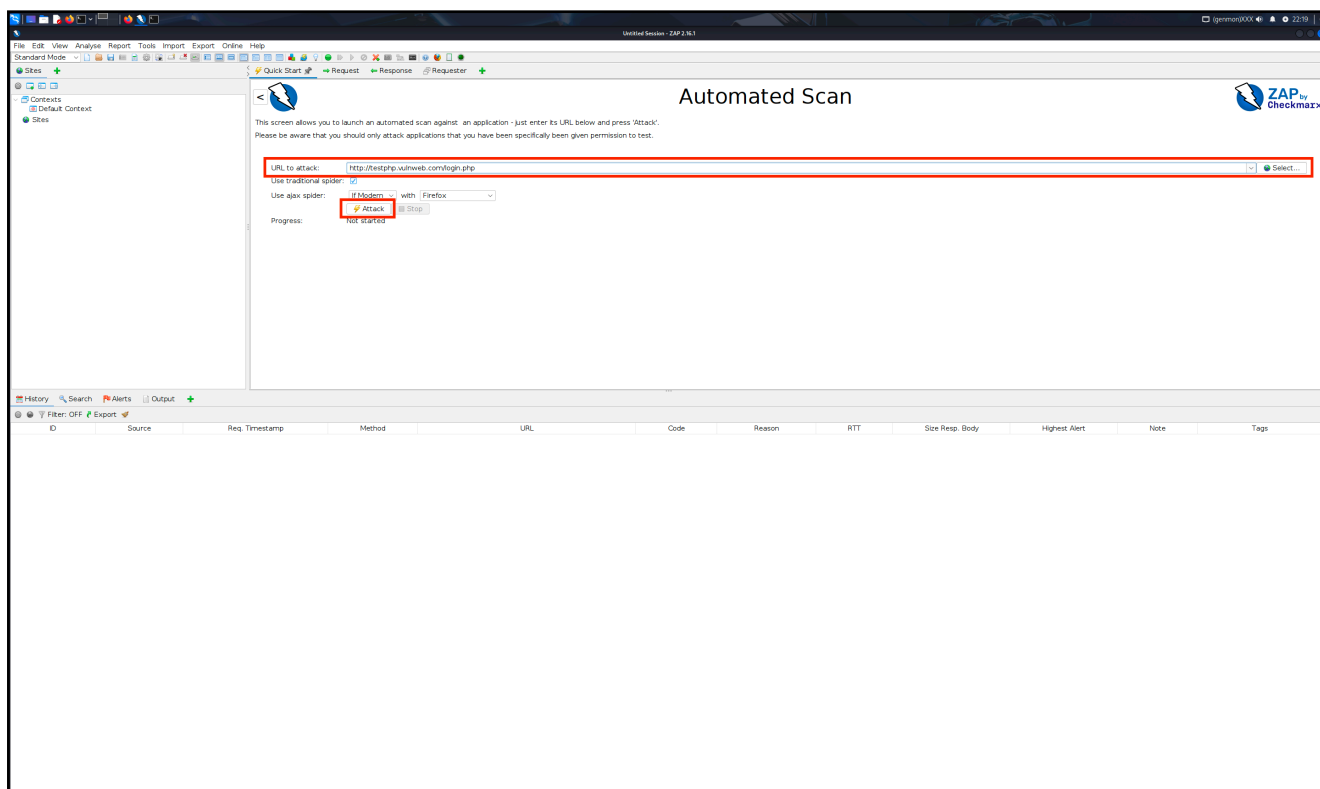
# STEP 3 : Launch ZAP - Type zaproxy in terminal to start the tool.



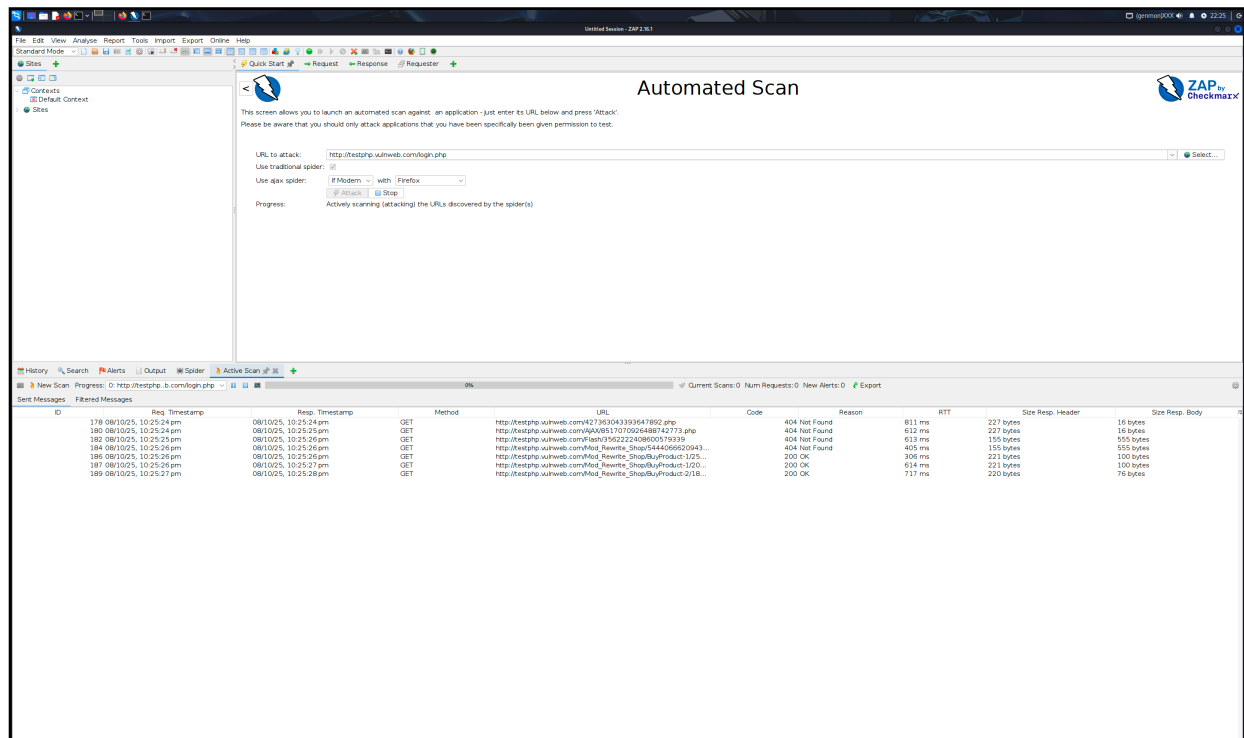
## STEP 4 : Click on “Automated Scan”.



STEP 5 : Enter the target URL into the “URL to attack” field, then click on “Attack” to begin scanning.



- ZAP performs active scanning by sending test payloads to the target and checking for security issues. It probes inputs, forms, and parameters to detect common vulnerabilities such as XSS and SQL injection.



## Result

The automated scan successfully completed using OWASP ZAP's active scanning feature.

## Conclusion

OWASP ZAP proved effective for performing an initial security assessment of the target web URL. Its automated scan feature helps detecting common vulnerabilities without requiring advanced setup, making it a reliable tool for beginners and ethical hacking labs.